Penetration Testing Using Burp Suite Lab

Table of Contents:

Overview

Environment Setup

Task 1: Intercept and Modify the request
- Task 1.1: Intercept HTTP traffic with Burp Proxy
- Task 1.2: Modifying HTTP requests with Burp Proxy

Task 2: Setting the Target Scope and Reissuing Requests
- Task 2.1: Set the target scope
- Task 2.2: Reissuing requests with Burp Repeater

Task 3: Setting the Test Scope and Mapping the website
- Task 3.1: Setting the initial test scope in Burp Suite
- Task 3.2: Mapping the target website with Burp Suite

Task 4: Testing for Vulnerabilities

Task 5: Submit the vulnerability

Appendix

Overview

Penetration testing is a systematic process of evaluating the security of a web application or system by simulating real-world attacks. It helps identify vulnerabilities such as SQL Injection, Cross-Site Scripting (XSS), authentication flaws, and misconfigurations before they can be exploited by malicious actors. By understanding how attackers think and operate, students gain practical insight into securing applications and protecting sensitive data. This lab focuses on introducing fundamental web application security concepts through controlled and legal testing environments.

Burp Suite is a widely used web application security testing tool that acts as an intercepting proxy between the user's browser and the target application. It allows testers to capture, analyze, and modify HTTP/HTTPS requests and responses in real time. With features such as Proxy, Repeater, and HTTP History, Burp Suite enables students to explore application behavior, manipulate inputs, and test for vulnerabilities efficiently. Its hands-on capabilities make it an essential tool for learning practical penetration testing techniques.

By completing this lab, students will

- gain a foundational understanding of how web applications communicate and how vulnerabilities can be identified and exploited.
- learn how to intercept and modify web traffic, analyze requests and responses, and use tools like Repeater to test different attack scenarios.
- develop a structured approach to penetration testing, including reconnaissance, analysis, and exploitation.

Overall, this lab equips learners with essential skills required for web security testing and prepares them for more advanced cybersecurity practices.

Set Up

Students are required to install Burp Suite (Community Edition) before starting the lab. The tool can be downloaded from the official website: https://portswigger.net/burp/communitydownload. Follow the installation steps based on your operating system and ensure that Burp Suite launches successfully. Students who are using **Kali Linux** do not need to install Burp Suite separately, as it comes pre-installed within the distribution. In such cases, simply locate and launch the tool from the applications menu.

Launching Burp Suite

After installing Burp Suite, students should launch the application. On startup, Burp Suite will prompt for project configuration. Select the option **"Temporary project in memory"** and proceed with the default settings. This option is recommended for this lab, as it allows you to quickly start working without saving data permanently.

Students should note that saving a project to disk is a feature available in the **Professional Edition** of Burp Suite. Since this lab uses the **Community Edition**, the "Temporary project" option must be selected. Another option, **"Open existing project"**, is used to reopen previously saved project files, which again applies only when working with saved projects in the Professional Edition.

After selecting the temporary project option, click **"Next"** and then **"Start Burp"** to access the main interface.

Task 1: Intercept and Modify the request

Task 1.1: Intercept HTTP traffic with Burp Proxy

Burp Proxy lets you intercept HTTP requests and responses sent between Burp's browser and the target server. This enables you to study how the website behaves when you perform different actions.

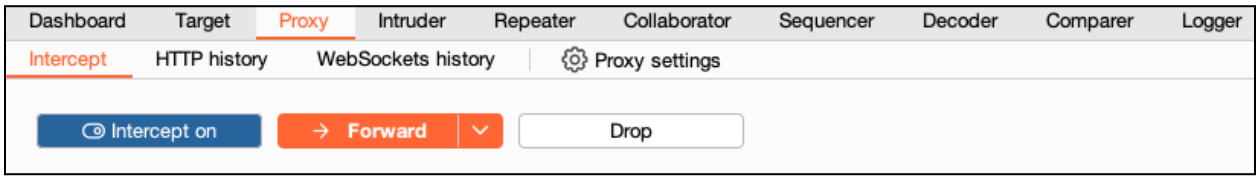
When using Burp Suite, **intercepting traffic** means temporarily stopping this communication so that the request can be viewed, analyzed, and modified before it is sent to the server.

In simple terms:

- Normally:
  Browser → Server → Response → Browser
- With interception:
  Browser → Burp Suite (pause) → Server → Response → Browser

Step 1: Launch Burp's browser

- Go to **Proxy → Intercept tab**
- Set the intercept toggle to **Intercept on**.



- Click **"Open Browser"** (Burp's built-in browser)

This browser is pre-configured to work with Burp, so no manual proxy setup is required.

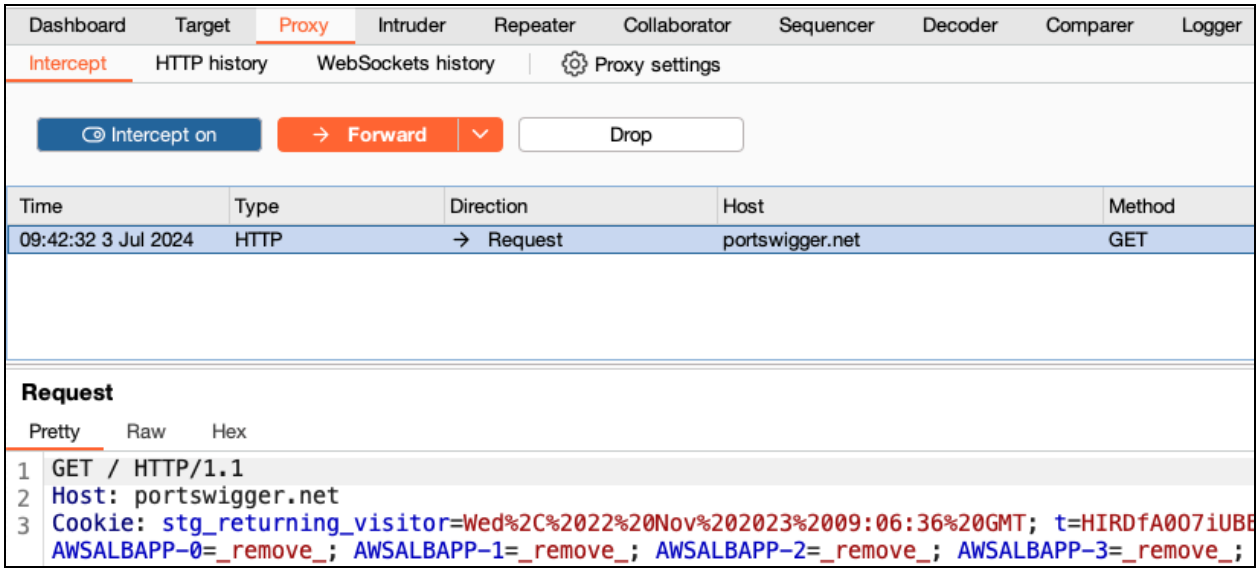
Note:

When Intercept is turned **ON**, the browser may appear to **freeze or not load the webpage**.
This happens because:

- The request is being **held (paused)** inside Burp Suite
- It is waiting for the user to take action

Step 2: Intercept a request

Using Burp's browser, try to visit https://portswigger.net and observe that the site doesn't load. Burp Proxy has intercepted the HTTP request that was issued by the browser before it could reach the server. You can see this intercepted request on the **Proxy > Intercept** tab.



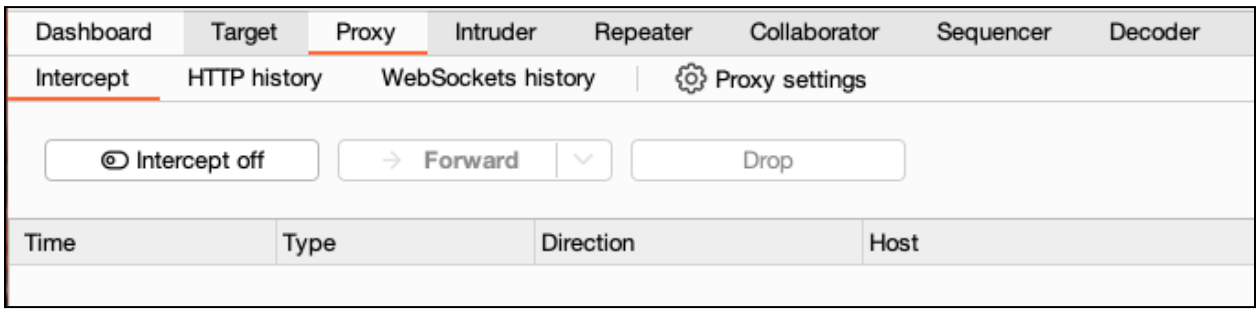
The request is held here so that you can study it, and even modify it, before forwarding it to the target server.

Step 3: Forward the request

Click the Forward button to send the intercepted request. Click Forward again to send any subsequent requests that are intercepted, until the page loads in Burp's browser. The Forward button sends all the selected requests.

Step 4: Switch off interception

Due to the number of requests browsers typically send, you often won't want to intercept every single one of them. Set the intercept toggle to **Intercept off**.

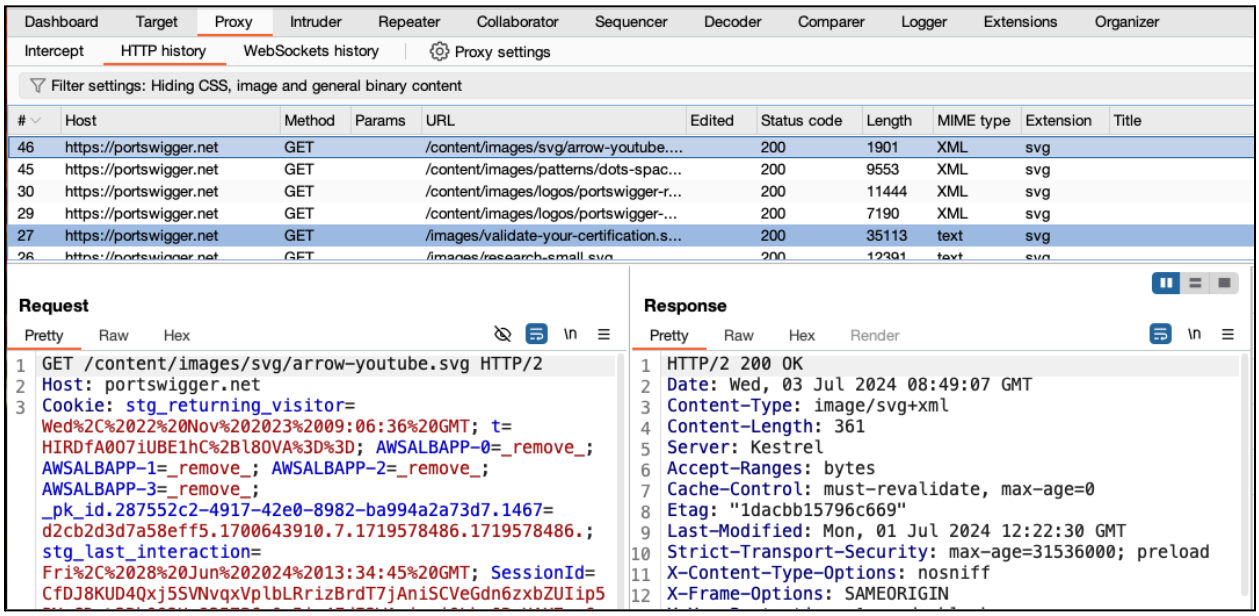


Go back to the browser and confirm that you can now interact with the site as normal.

Step 5: View the HTTP history

In Burp, go to the **Proxy > HTTP history** tab. Here, you can see the history of all HTTP traffic that has passed through Burp Proxy, even while intercept was switched off.

Click on any entry in the history to view the raw HTTP request, along with the corresponding response from the server.



This lets you explore the website as normal and study the interactions between Burp's browser and the server afterward, which is more convenient in many cases.

Questions:

1. How can intercepting traffic help in finding vulnerabilities?
2. What risks arise if sensitive data is sent without encryption?
3. How can an attacker misuse intercepted data?

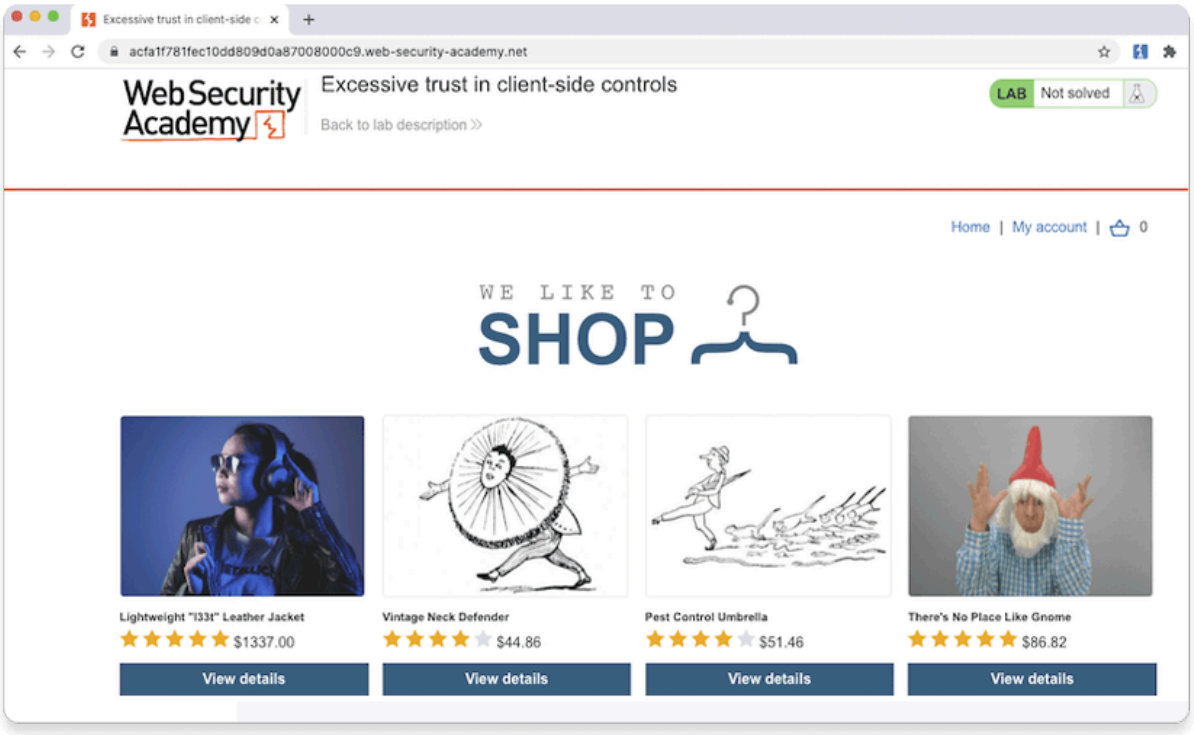
Task 1.2: Modifying HTTP requests with Burp Proxy

In this task, you'll learn how to modify intercepted requests in Burp Proxy. This enables you to manipulate these requests in ways that the website isn't expecting, in order to see how it responds. Using one of the deliberately vulnerable websites, you'll see how this can help you identify and exploit real vulnerabilities.
To follow along, you'll need an account on portswigger.net. If you don't have one already, registration is free and it grants you full access to the Web Security Academy.

Step 1: Access the vulnerable website in Burp's browser

In Burp, go to the **Proxy > Intercept** tab and make sure interception is switched off.
Launch Burp's browser and use it to visit the following URL:
https://portswigger.net/web-security/logic-flaws/examples/lab-logic-flaws-excessive-trust-in-client-side-controls

When the page loads, click **Access the lab**. If prompted, log in to your portswigger.net account. After a few seconds, you will see your own instance of a fake shopping website.



Step 2: Log in to your shopping account

On the shopping website, click **My account** and log in using the following credentials:

Username: wiener
Password: peter

Notice that you have just $100 of store credit.

Step 3: Find something to buy

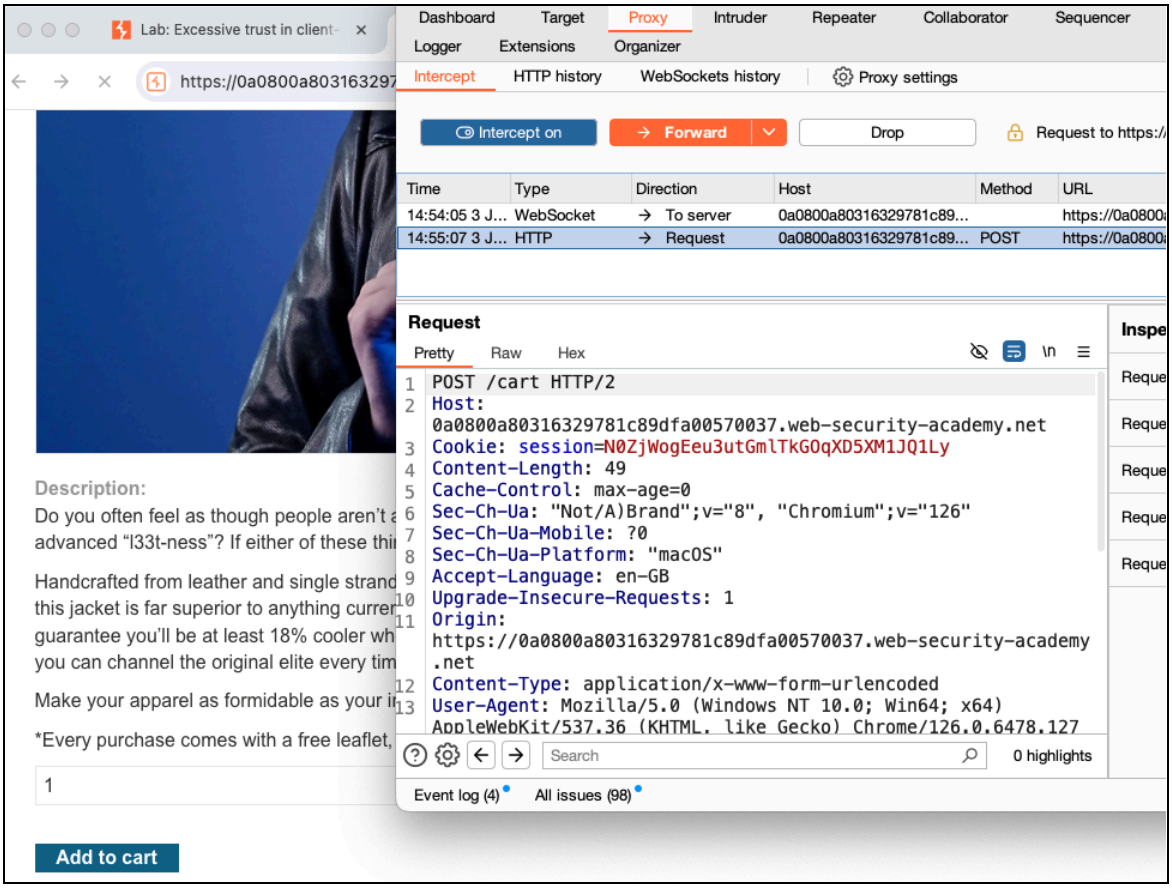
Click **Home** to go back to the home page. Select the option to view the product details for the **Lightweight "l33t" leather jacket**.

Step 4: Study the add to cart function

In Burp, go to the **Proxy > Intercept** tab and switch interception on. In the browser, add the leather jacket to your cart to intercept the resulting *POST /cart* request.

Note:

You may see more than one request on the **Proxy > Intercept** tab if the browser is doing something else in the background. In this case, select the *POST /cart* request.



Study the intercepted request and notice that there is a parameter in the body called price, which matches the *price* of the item in cents.

Step 5: Modify the request

Change the value of the *price* parameter to 1 and click **Forward > Forward all** to send the modified request to the server, along with any other intercepted requests.

```
20
21 productId=1&redir=PRODUCT&quantity=1&price=1
```

Switch interception off again so that any subsequent requests can pass through Burp Proxy uninterrupted.

Step 6: Exploit the vulnerability

In Burp's browser, click the basket icon in the upper-right corner to view your cart. Notice that the jacket has been added for just one cent.

Note:

There is no way to modify the price via the web interface. You were only able to make this change thanks to Burp Proxy.

Click the **Place order** button to purchase the jacket for an extremely reasonable price.

Questions:

1. What is the role of interception in modifying requests?
2. How can you identify editable fields in a request?
3. What will happen if you remove a required parameter from a request?

Task 2: Setting the Target Scope and Reissuing Requests

Task 2.1: Set the target scope

In this task, you'll learn how to set the target scope for your work in Burp Suite. The target scope tells Burp exactly which URLs and hosts you want to test. This enables you to filter out the noise generated by your browser and other sites, so you can focus on the traffic that you're interested in.

Step 1: Launch Burp's browser

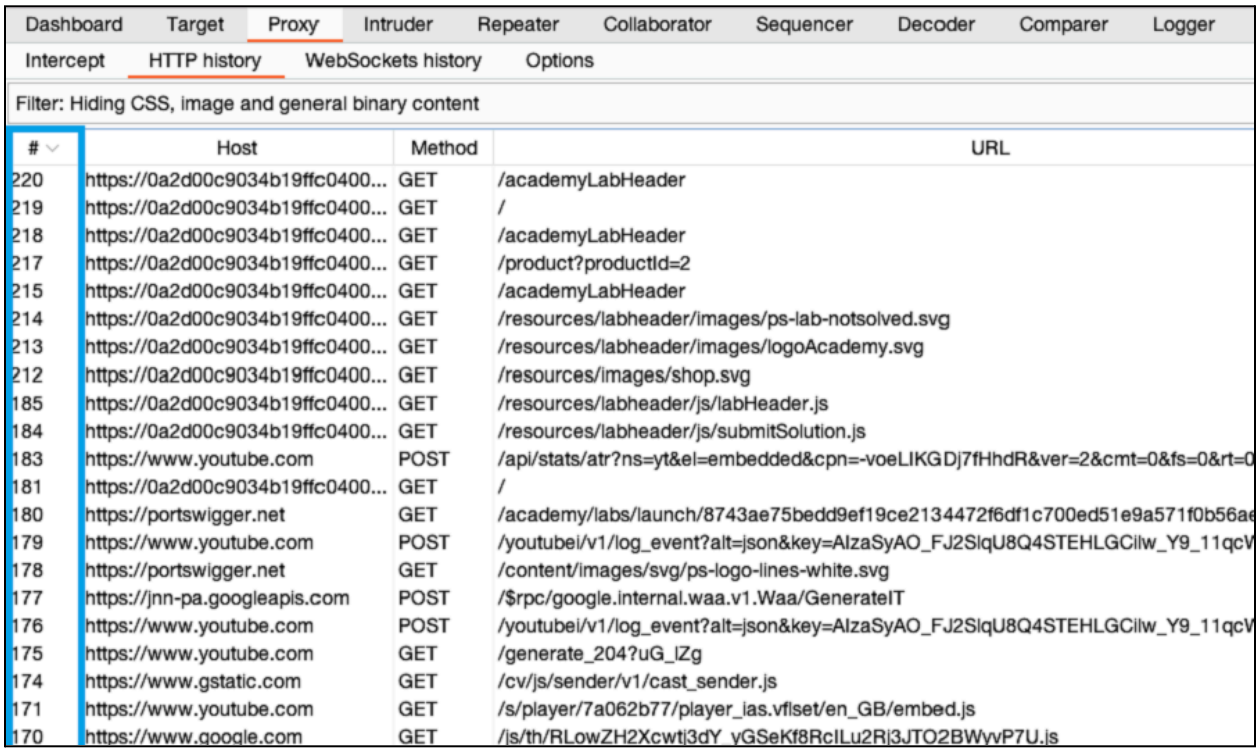
Launch Burp's browser and use it to visit the following URL:
https://portswigger.net/web-security/information-disclosure/exploiting/lab-infoleak-in-error-messages
When the page loads, click **Access the lab**. If prompted, log in to your portswigger.net account. After a few seconds, you will see your own instance of a fake shopping website.

Step 2: Browse the target site

In the browser, explore the site by clicking on a couple of the product pages.

Step 3: Study the HTTP history

In Burp, go to the **Proxy > HTTP history** tab. To make this easier to read, keep clicking the header of the leftmost column (#) until the requests are sorted in descending order. This way, you can see the most recent requests at the top.

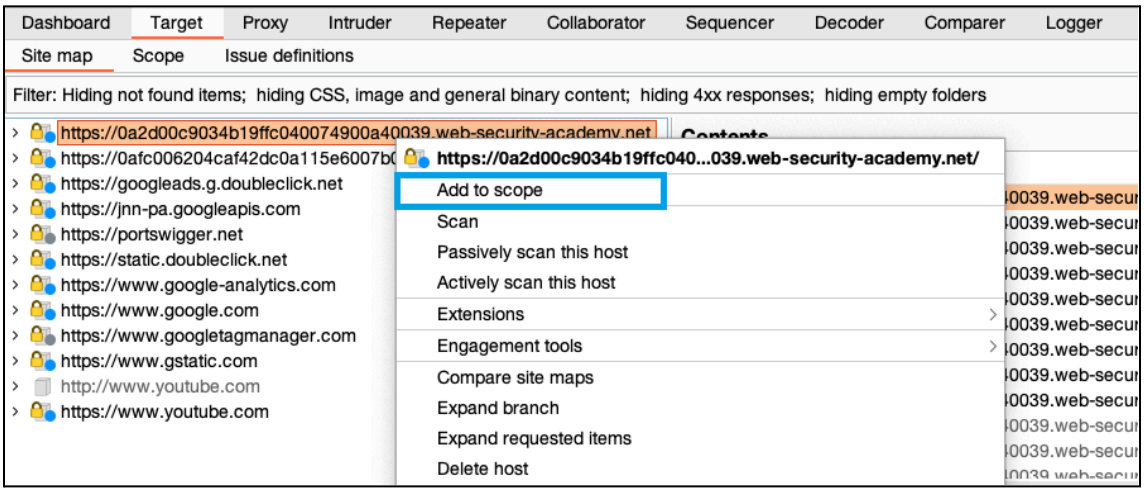


#	Host	Method	URL
220	https://0a2d00c9034b19ffc0400...	GET	/academyLabHeader
219	https://0a2d00c9034b19ffc0400...	GET	/
218	https://0a2d00c9034b19ffc0400...	GET	/academyLabHeader
217	https://0a2d00c9034b19ffc0400...	GET	/product?productId=2
215	https://0a2d00c9034b19ffc0400...	GET	/academyLabHeader
214	https://0a2d00c9034b19ffc0400...	GET	/resources/labheader/images/ps-lab-notsolved.svg
213	https://0a2d00c9034b19ffc0400...	GET	/resources/labheader/images/logoAcademy.svg
212	https://0a2d00c9034b19ffc0400...	GET	/resources/images/shop.svg
185	https://0a2d00c9034b19ffc0400...	GET	/resources/labheader/js/labHeader.js
184	https://0a2d00c9034b19ffc0400...	GET	/resources/labheader/js/submitSolution.js
183	https://www.youtube.com	POST	/api/stats/atr?ns=yt&el=embedded&cpn=-voeLIKGDj7fHhdR&ver=2&cmt=0&fs=0&rt=0
181	https://0a2d00c9034b19ffc0400...	GET	/
180	https://portswigger.net	GET	/academy/labs/launch/8743ae75bedd9ef19ce2134472f6df1c700ed51e9a571f0b56ae
179	https://www.youtube.com	POST	/youtubei/v1/log_event?alt=json&key=AIzaSyAO_FJ2SlqU8Q4STEHLGCilw_Y9_11qcV
178	https://portswigger.net	GET	/content/images/svg/ps-logo-lines-white.svg
177	https://jnn-pa.googleapis.com	POST	/$rpc/google.internal.waa.v1.Waa/GenerateIT
176	https://www.youtube.com	POST	/youtubei/v1/log_event?alt=json&key=AIzaSyAO_FJ2SlqU8Q4STEHLGCilw_Y9_11qcV
175	https://www.youtube.com	GET	/generate_204?uG_lZg
174	https://www.gstatic.com	GET	/cv/js/sender/v1/cast_sender.js
171	https://www.youtube.com	GET	/s/player/7a062b77/player_ias.vflset/en_GB/embed.js
170	https://www.google.com	GET	/js/th/RLowZH2Xcwtj3dY_yGSeKf8RcILu2Rj3JTO2BWyvP7U.js

Notice that the HTTP history shows details about each request that the browser has made, including requests to third-party websites that you're not interested in, such as YouTube and Google Analytics.

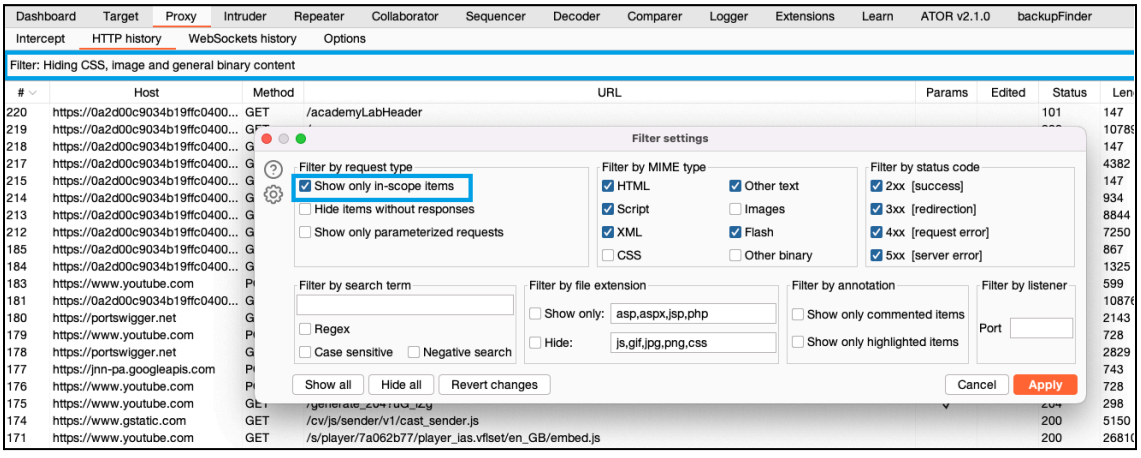
Step 4: Set the target scope

Go to **Target > Site map**. In the left-hand panel you can see a list of hosts that your browser has interacted with. Right-click on the node for the target site and click **Add to scope**. When prompted in a pop-up window, click **Yes** to exclude out-of-scope traffic.



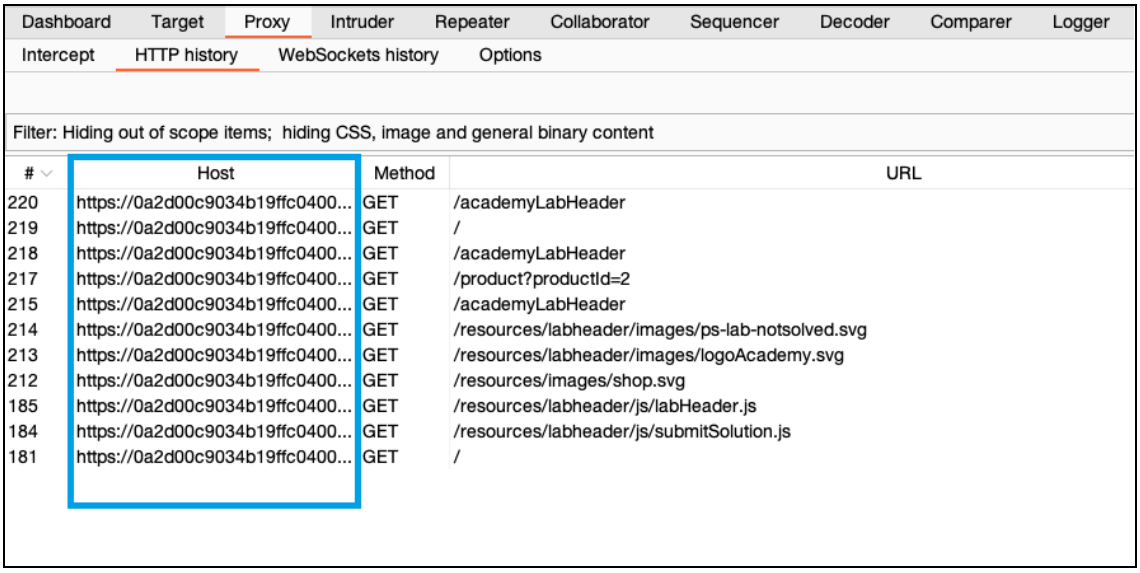
Step 5: Filter HTTP history

Click on the display filter above the HTTP history and select **Show only in-scope items**.



Scroll back through your HTTP history. Notice that it now only shows entries from the target website. All other entries have been hidden. This greatly simplifies the history to only include items you're interested in.

If you continue to browse the target site, notice that out-of-scope traffic is no longer logged in the site map or proxy history.



Task 2.2: Reissuing requests with Burp Repeater

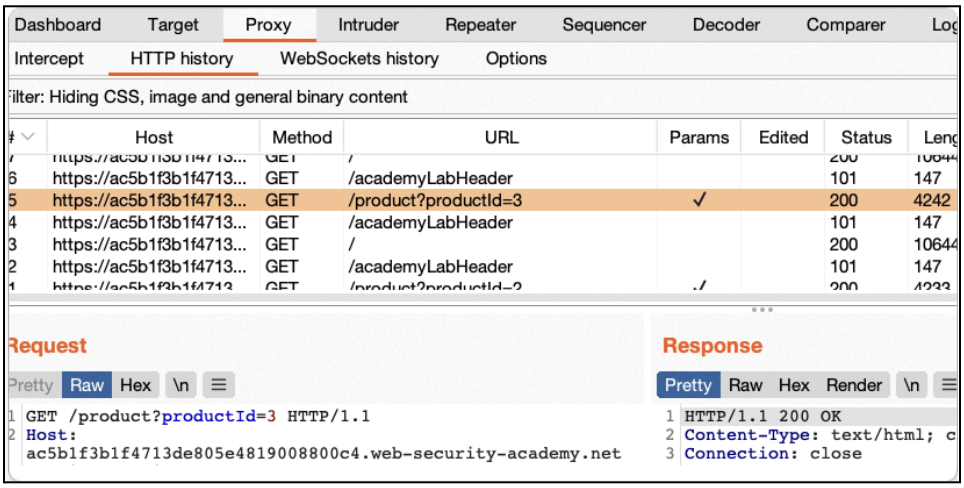
In this task, you'll use Burp Repeater to send an interesting request over and over again. This lets you study the target website's response to different input without having to intercept the request each time. This makes it much simpler to probe for vulnerabilities, or confirm ones that were identified by Burp Scanner, for example.

Sending a request to Burp Repeater

The most common way of using Burp Repeater is to send it a request from another of Burp's tools. In this example, we'll send a request from the HTTP history in Burp Proxy.

Step 1: Identify an interesting request

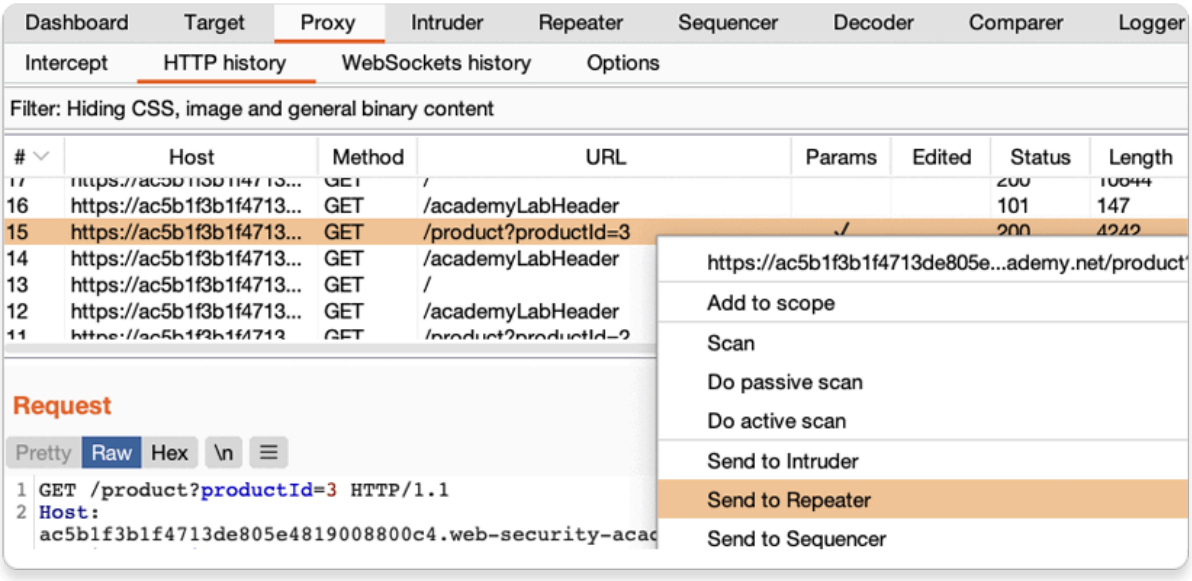
In the previous tutorial, you browsed a fake shopping website. Notice that each time you accessed a product page, the browser sent a *GET /product* request with a *productId* query parameter.



Let's use Burp Repeater to look at this behavior more closely.

Step 2: Send the request to Burp Repeater

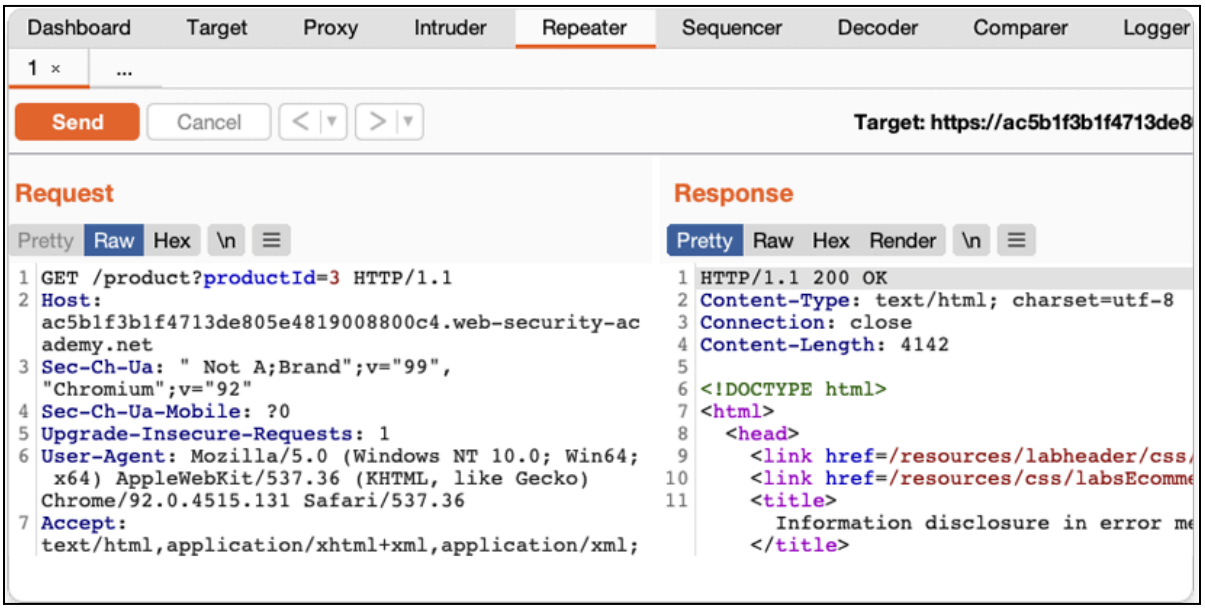
Right-click on any of the *GET /product?productId=[...]* requests and select **Send to Repeater**.



Go to the **Repeater** tab to see that your request is waiting for you in its own numbered tab.

Step 3: Send the request and view the response

Click **Send** and view the response from the server. You can resend this request as many times as you like and the response will be updated each time.

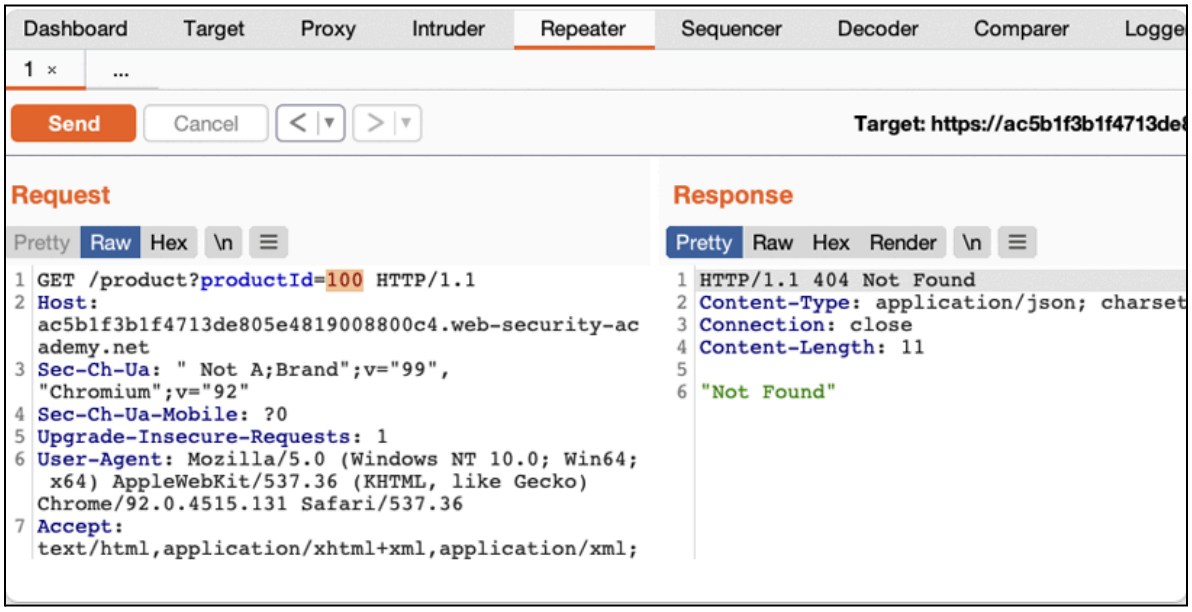


Testing different input with Burp Repeater

By resending the same request with different input each time, you can identify and confirm a variety of input-based vulnerabilities. This is one of the most common tasks you will perform during manual testing with Burp Suite.

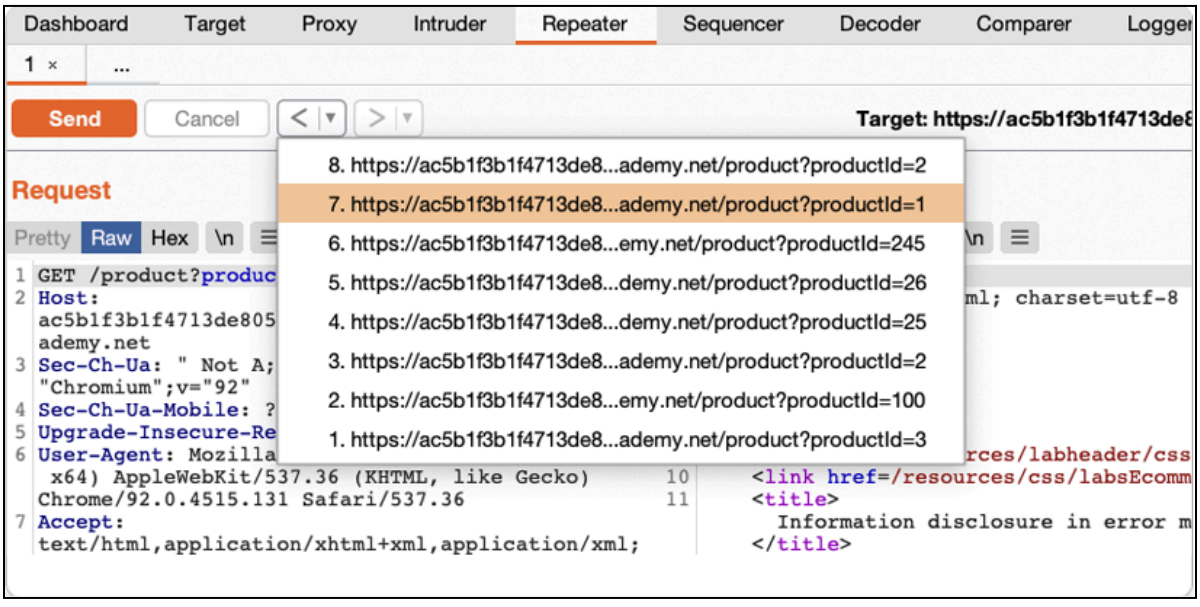
Step 1: Resend the request with different input

Change the number in the *productId* parameter and resend the request. Try this with a few arbitrary numbers, including a couple of larger ones.



Step 2: View the request history

Use the arrows to step back and forth through the history of requests that you've sent, along with their matching responses. The drop-down menu next to each arrow also lets you jump to a specific request in the history.

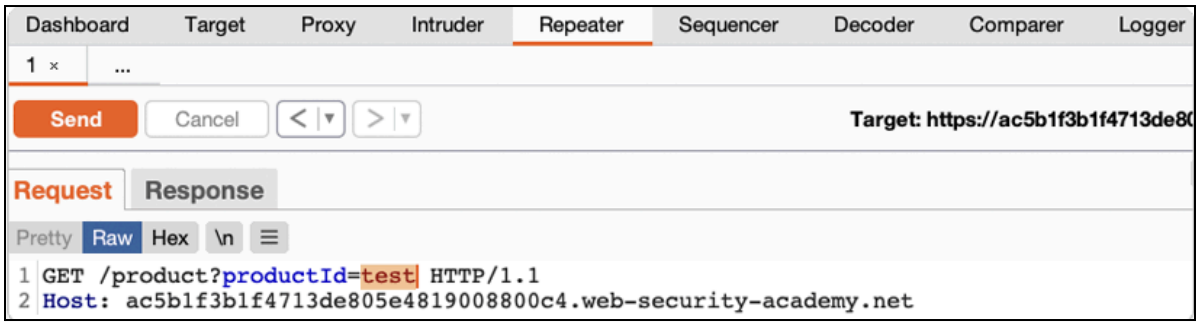


This is useful for returning to previous requests that you've sent in order to investigate a particular input further.

Compare the content of the responses, notice that you can successfully request different product pages by entering their ID, but receive a *Not Found* response if the server was unable to find a product with the given ID. Now we know how this page is supposed to work, we can use Burp Repeater to see how it responds to unexpected input.

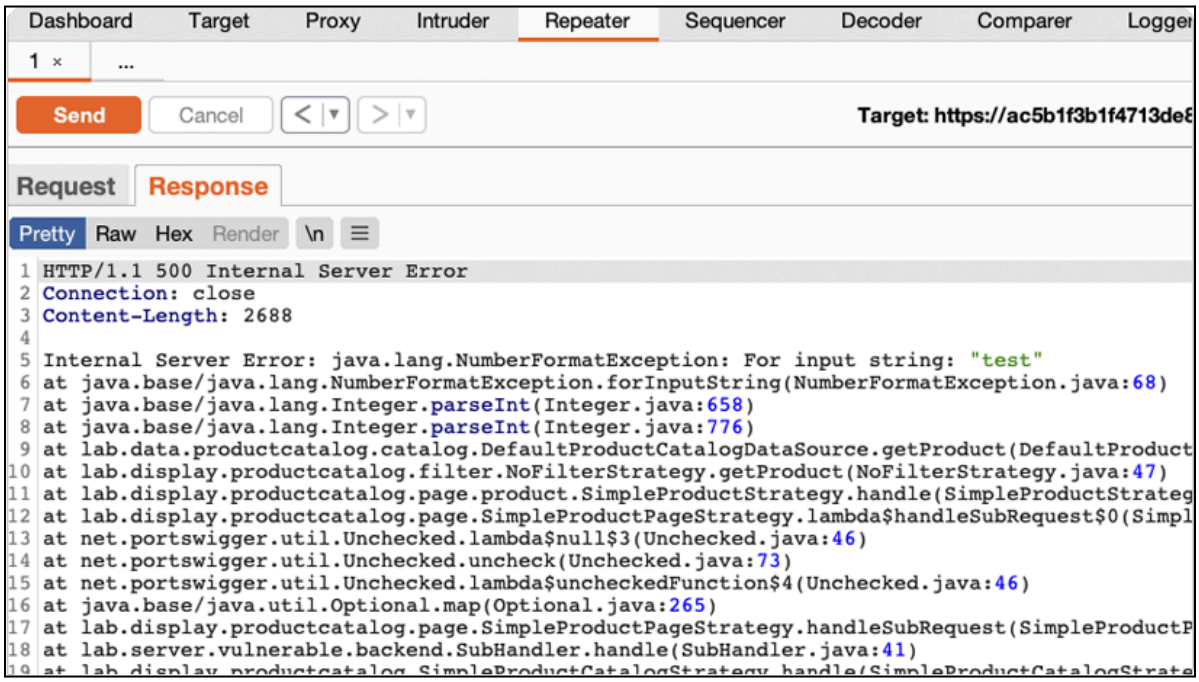
Step 3: Try sending unexpected input

The server seemingly expects to receive an integer value via this *productId* parameter. Let's see what happens if we send a different data type.
Send another request where the *productId* is a string of characters.



Step 4: Study the response

Observe that sending a non-integer *productId* has caused an exception. The server has sent a verbose error response containing a stack trace.



Notice that the response tells you that the website is using the Apache Struts framework - it even reveals which version.

```
37 at java.base/java.util.concurrent.ThreadPoolExecutor$Worker.run(ThreadPoolExecutor.java:628)
38 at java.base/java.lang.Thread.run(Thread.java:835)
39
40 Apache Struts 2 2.3.31
```

In a real scenario, this kind of information could be useful to an attacker, especially if the named version is known to contain additional vulnerabilities.

Questions:

1. What types of inputs can be tested using Repeater?
2. You want to test multiple payloads for a login form. Which tool will you use and why?
3. How can Repeater be used to test for SQL Injection or XSS?
4. What happens if sensitive or unrelated domains are included in scope?
5. What happens if scope is not properly set?

Task 3: Setting the Test Scope and Mapping the website

Task 3.1: Setting the initial test scope in Burp Suite

By default, as you use Burp's browser, Burp logs all HTTP or WebSocket messages for further analysis. By setting a scope, you can tell Burp which URLs you want to test and which you don't want to test. For example, you may want to exclude URLs that:

- You don't have permission to test.
- Aren't safe to test. For example, URLs that contain potentially dangerous functionality.
- Aren't relevant. Once you have set the scope, you can use the filters in the Target site map and Proxy history to screen out some of the noise.

Note:
In Burp Suite Community Edition, your scope settings are lost when you close Burp, along with any other data. You can save the scope settings as part of a project file in Burp Suite Professional.

Adding URLs to the scope

To add a URL to your scope:

1. Click **Scope settings** on the lower toolbar to open the **Settings** dialog.
2. Scroll to the **Target scope** setting.
3. Under **Include in scope**, click **Add**. The **Add** prefix for in-scope URLs dialog opens.
4. Enter the prefix for the URLs that you want to match, then click **OK**.
5. When prompted, choose whether to stop logging out-of-scope traffic. This can provide performance benefits.

The prefix is added to the **Include in scope** list. Any URL that starts with this exact prefix is now in scope. Any URL that doesn't start with a prefix from the list is out of scope. For example, if you add *https://example.com*, requests to any path on this domain are in scope if they're accessed over HTTPS.

Excluding URLs from the scope

After you add a URL to your scope, you may want to exclude specific paths that are a subset of the in-scope prefixes, such as *https://example.com/admin*. To exclude a URL from your scope:

1. Click **Scope settings** on the lower toolbar to open the **Settings** dialog.
2. Scroll to the **Target scope** setting.
3. Under **Exclude from scope**, click **Add**. The **Add prefix for out-of-scope URLs** dialog opens.
4. Enter a prefix for the URLs that you want to exclude, then click **OK**.

The prefix is added to the **Exclude from scope** list. A URL is now in scope if it starts with an in-scope prefix, but does not start with an out-of-scope prefix.

Questions:

1. What type of URLs should NOT be included in scope?
2. What are the consequences of testing out-of-scope targets?

Task 3.2: Mapping the target website with Burp Suite

The best way to start testing an application is to map its contents. This enables you to understand what the application does and how it behaves. You can then identify interesting areas that you want to probe for vulnerabilities.
Burp Suite enables you to use a combination of manual and automated tools to map the application. You can use these to discover both visible and hidden content.

Mapping the visible attack surface with Burp Suite

To discover locations that are available to audit, you need to map the target application's visible attack surface. This refers to the endpoints that are explicitly used by the domains you're testing. Make sure you map the entire application thoroughly, so that you don't miss anything interesting.

Steps

You can follow along with the process below using ginandjuice.shop, our deliberately vulnerable demonstration site. To map the visible attack surface:

1. Open Burp's browser and go to your target application.
2. Without closing the browser, go to **Target > Site map**. Notice that a node has been automatically added to represent the target domain. If no node is present, go to the **Dashboard** and make sure that the default **Live passive crawl from Proxy** task is running. This task adds items to the site map as traffic is proxied through Burp.
3. If you're using Burp Suite Community Edition, make sure you fully explore the application:
    a. If you have any application login credentials, or are able to create your own user, log in and explore the authenticated areas of the site.
4. In the site map, notice that some endpoints that are grayed out. These are locations that are explicitly referenced in a response, but have not been requested.
    a. To discover additional content, select any interesting grayed out endpoint. Right-click and select **Request in browser > In original session**. A dialog opens with a URL for the request.
    b. To open the request, copy the URL, then paste it into Burp's browser.
    c. Continue to browse the application.

Note:

In Burp Suite **Professional Edition**, features like automated crawling help map the website and discover endpoints quickly.

Since we are using the **Community Edition**, these features are not available. Therefore, students need to **manually browse the application** (click links, submit forms, explore pages) to build the site map.

Questions:

1. What is meant by the attack surface of a web application?
2. If a tester skips the mapping phase, what problems can occur?
3. Identify at least 5 different endpoints/pages.
4. You missed a hidden page during mapping. What could be the impact?

Note on Analyzing Attack Surface (Pro vs Community):

In Burp Suite **Professional Edition**, advanced features are available to **automatically analyze the attack surface** of a web application. These include tools like the **Target Analyzer and Burp Scanner**, which can identify dynamic URLs, parameters, and potential vulnerabilities automatically from the site map.

These features are highly useful in penetration testing because they:

- Quickly identify all possible entry points (URLs, parameters)
- Automatically detect vulnerabilities like SQL Injection and XSS
- Reduce manual effort and save time during testing

However, since we are using the **Community Edition**, these automated analysis features are not available. Therefore, students need to:

- Manually review the site map
- Identify parameters and endpoints
- Perform testing using tools like Repeater

Task 4: Testing for Vulnerabilities

After mapping the application and analyzing its attack surface, the next step is to test it for vulnerabilities. This involves checking how the application handles authentication, access control, user input, and other security-critical functionality.
Burp Suite provides a range of tools to support vulnerability testing, from targeted manual techniques to automated scanning.

The **vulnerability testing** phase heavily relies on **Pro features** (like Scanner, Intruder automation, etc.). Since automated scanning is not available in Community Edition:
Students must perform manual testing using:

- Proxy (intercept requests)
- Repeater (modify & resend requests)

Step 1: Enable Interception

- Go to **Proxy → Intercept**
- Turn **Intercept ON**

Step 2: Open Target Website

- Visit a vulnerable/test website (e.g., Juice Shop or any demo site)
- Perform an action like:
  - Login
  - Search
  - Form submission

Burp will capture the request

Step 3: Send Request to Repeater

- Right-click intercepted request
- Click **"Send to Repeater"**
- Turn **Intercept OFF** (to avoid blocking browser)

Step 4: Testing Activities

❖ Test for SQL Injection (Basic)

- In Repeater, locate input fields (e.g., username/password)
- Replace value with:
  ' OR 1=1 --
- Click **Send**

Observe:

- Did login bypass occur?
- Any SQL errors?

❖ Test for XSS (Cross-Site Scripting)

- Modify input parameter:
  <script>alert(1)</script>
- Click **Send**

Observe:

- Is the script reflected in response?
- Any alert triggered (in browser-based testing)?

❖ Parameter Tampering

- Find a numeric parameter (e.g., *id=1*)
- Change it to:
  - *id=2*
  - *id=999*
- Click **Send**

Observe:

- Does it show different user/data?

❖ Authentication Testing

- Capture a login request again
- Modify:
  - *Username*
  - *Password*
- Try:
  - *Empty values*
  - *Random values*

Observe:

- Any unexpected login success?

❖ Access Control Testing

- Try accessing restricted pages directly (without login)
- Modify parameters like:
  - *role=user → role=admin*

Observe:

- Are you able to access unauthorized content?

Step 5: Analyze Responses

- Compare:
  - Normal response
  - Modified response

Look for:

- Error messages
- Data leakage
- Unusual behavior

Provide screenshots wherever necessary.

Task 5: Submit the vulnerability

Students should submit:

- At least **one vulnerability** found in the given website i.e., http://demo.testfire.net
  Username: jdoe
  Password: jdoe
- Payload used
- Screenshot of response
- Short explanation of findings

Important Note:

- Do not test any website without proper authorization.
- Do not use these skills for illegal activities like hacking or data theft.
- Do not perform aggressive attacks such as brute force or DoS.
- Do not access, store, or misuse real user data.
- Do not test out-of-scope targets or systems.
- Do not share exploits or vulnerabilities publicly.
- Do not misuse tools like Burp Suite for unethical purposes.
- Use these skills only for learning and ethical security testing.

Appendix: Burp Suite Tools Overview

- Dashboard - The Dashboard tab provides a central location for monitoring and controlling all of the automated tasks in your project, such as vulnerability scans or live tasks.
- Target - This tool contains detailed information about your target applications, and lets you drive the process of testing for vulnerabilities.
- Burp's browser - This browser is preconfigured to work with the full functionality of Burp Suite right out of the box.
- Proxy - This is an intercepting web proxy that operates as a man-in-the-middle between the end browser and the target web application. It lets you intercept, inspect and modify the raw traffic passing in both directions.
- Scanner Professional - This is an advanced web vulnerability scanner, which can automatically crawl content and audit for numerous types of vulnerabilities.
- Intruder - This is a powerful tool for carrying out automated customized attacks against web applications. It is highly configurable and can be used to perform a wide range of tasks to make your testing faster and more effective.
- Repeater - This is a tool for manually manipulating and resending individual messages, and analyzing the application's responses.
- Sequencer - This is a sophisticated tool for analyzing the quality of randomness in an application's session tokens or other important data items that are intended to be unpredictable.
- Decoder - This is a useful tool for performing manual or automated decoding and encoding of application data.
- Comparer - This is a handy utility for performing a visual "diff" between any two items of data, such as pairs of similar HTTP messages.
- Logger - This is a tool for recording and analyzing HTTP traffic that Burp Suite generates.
- Inspector - This provides some useful features for analyzing and editing HTTP and WebSockets messages.
- Collaborator Professional - This is a manual tool for identifying out-of-band vulnerabilities.
- DOM Invader - This is a tool for finding DOM XSS vulnerabilities.
- Clickbandit - This is a tool for generating Clickjacking attacks.
- Message editor - This is a tool for viewing and editing HTTP requests and responses throughout Burp.
- Engagement tools Professional - Configure various engagement-related tasks.
- Search - This is a tool for performing searches in Burp Suite.
- Command palette - This is a tool for quickly finding and running commands using your keyboard.
- Infiltrator - This is a tool for detecting whether Burp's input is passed to potentially unsafe APIs.

- Organizer - This is a tool for storing and annotating HTTP messages that you want to investigate later.
- Context menu - The context menu provides quick access to a variety of tools and functions throughout Burp Suite.
- Filter settings - These settings enable you to filter the messages that are shown in various Burp Suite tools.